

Building a reference data model for data privacy in large organizations through a subdomain taxonomy-informed semantic reconciliation of the W3C Data Privacy Vocabulary.

Brice Dobson
PUBP 672

Georgia Tech

1

Bottom Line Up Front (BLUF)

- Data Privacy is hard for large organizations
- There are hundreds of frameworks, ontologies, and taxonomies that help do things *within* data privacy.
 - Some aren't detailed enough to implement *well*.
 - Very few consider interoperability across domains.
 - None of them consider an organization's interoperability needs.
- This project asks "What would a truly unified data model for privacy look like for a large organization?"

Results: a) Made the data model b) Identified [x] previously latent decision points c) Identified [x] "bugs" in the W3C DPV

Introduction Background and Problem Approach Findings Solution Conclusions Georgia Tech

2

Background and Problem

Georgia Tech

3

Problem Positioning

01 The Law
"Everybody seems to have a privacy law these days"

02 Complexity
"Large organizations do business in dozens or hundreds of places."

03 Existing Domain-Based Frameworks

04 Commercial Tools
"We can help you be better at this, but don't want you to be so good you don't need us."

Prior Art
"There are many opinions on how certain things in privacy should be done."

Delegated Decisions
"We can help you be better at this, but don't want you to be so good you don't need us."

Introduction Background and Problem Approach Findings Solution Conclusions Georgia Tech

4

Pain points by problem facet

Regulatory Environment	Large Organizations	External References	Commercial Tools
- At least 144 countries now have laws addressing privacy and data protection obligations of organizations. (IAPP) - Comprehensive vs. sectoral approaches. - Enforcement interest is broadening. (GDPR Hub) - Individual invocation of rights up 128%.	- Top 100 MNEs average more than 500 affiliate companies across more than 50 countries. (UN) - Large orgs often can't support full legal teams in every country.	- Hundreds of these... - Authors can be governmental, standards based (e.g. ISO, NIST), academic, or commercial. - Each body of work has a different "level of analysis". Limited care for conflict or interoperability.	- Commercial tools must implement data structures for their feature support. These reflect decisions - These may lack extensibility, which creates maturity ceiling. - Must satisfy a diverse customer base with different risk and maturity profiles.

Introduction Background and Problem Approach Findings Solution Conclusions Georgia Tech

5

The W3C DPV

Understanding the DPV

- An ontology shows interactions between things.
- Excellent basic starting point.
- Lacking detail necessary for operationalization.

Introduction Background and Problem Approach Findings Solution Conclusions Georgia Tech

6

Conceptualizing a Solution

- **The main idea:** This is a data problem first and there is a level of normalization that can make all these linked-ideas compatible. In a perfect world, drift from this is a function of maturity-keying, which is ideally formally accepted risk.
- **A secondary idea:** There are latent decisions, that if made explicit, could improve speed and quality of individual organizational implementations of the DPV or privacy data models more generally.
- **Tertiary Idea:** There may be flaws in the W3C DPV that can be corrected.



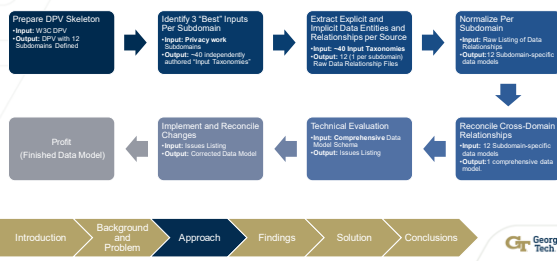
Methodology



7

8

High Level Methodology



9

Methodology: Key Figures

Phase	Results
1 – Prepare DPV Skeleton	12 Subdomains Defined + 1 Informational
2 – Identify Input Taxonomies	49 Accepted Input Taxonomies
3 – Extract Data Entities, Relationships, and Attributes	480 Raw Entries, incl. a core of 60 entities and 87 relationships.
4 – Normalization per Subdomain	160 potential gaps, decision points, or missing areas of needed definition. 36% Avg. compression.
5 – Cross-Subdomain Relationships	87 Cross-Domain "Jumps" (Joins)
6 – Technical Evaluation	Reconciled 45 Issues and Latent Decision Points Across 100 Test Cases Over 12 Runs.
7 – Final Reconciliation	2 Gaps Raised to W3C



10

Evaluation Methodology

Quantitative (Internal Validity)

- Test Driven Model Refinement
- 100 Test Cases
 - Derived From:
 - Privacy Workforce Taxonomy (NIST)
 - Privacy Operational Lifecycle (AAPP)
 - YAML format, each test case had a satisfaction claim that was translated to a SPARQL SELECT query.
- The data model was declared as Turtle RDFS/OWL ontology with 52 classes, 96 properties, and several typed variants.
- Python chema validator built using rdflib to check for missing entities, format gaps, missing relationships, missing attributes and typing, mismatched domains, mismatched output ranges.
- Reconciled issues each run, ran 12 times before all issues reconciled.

Qualitative (External Validity)

- [4] Submissions to the W3C related to the DPV.
- Feedback were [still waiting]
- Feedback prodded into the final work product, even if about the DPV.



11

Analysis, Observation, and Findings



12

Findings and Observations

- Identified:
 - [x] (Mostly) Latent Decision Points
 - [x] issues in the W3C DPV
 - Significant disparities in rework dynamics between maturity levels.
- Observed needs for:
 - More robust sub-schemas for entities that practitioners must instantiate for actual usage.
 - Reification needs for items previously represented as types.
 - Better accounting for time as a construct.



13

Reference Data Model Characteristics

Domain	Entities	Relationships	Cross-Domain	Decisions	Rework Points
1 - Processing Inventory	2	20	17	7	3
2 - Purpose Specification & Governance	2	5	6	3	1
3 - Personal Data Inventory & Classification	7	14	7	6	3
4 - Legal Basis Management	5	8	16	2	5
5 - Entities, Roles, & Accountability	12	30	23	6	6
6 - Consent Management	4	10	9	5	3
7 - Data Subject Rights Management	5	9	5	6	3
8 - Notice & Transparency	5	4	6	2	6
9 - Risk & Impact Assessment	3	8	12	4	9
10 - Control Measures	4	9	7	4	6
11 - Incident & Breach Management	5	9	10	2	3
12 - Regulatory Reporting & Disclosure	5	3	5	2	2



14

Reference Data Model Rework Distribution

Domain	L1 -> L2	L2 -> L3	L3 -> L4	L4 -> L5	Totals
1 - Processing Inventory	1	1	3	1	6
2 - Purpose Specification & Governance	1	1	1	1	4
3 - Personal Data Inventory & Classification	1	1	3	1	6
4 - Legal Basis Management	1	1	5	1	8
5 - Entities, Roles, & Accountability	1	1	6	1	9
6 - Consent Management	1	1	3	1	6
7 - Data Subject Rights Management	1	1	3	1	6
8 - Notice & Transparency	1	1	4	1	7
9 - Risk & Impact Assessment	1	2	6	1	10
10 - Control Measures	1	1	5	1	8
11 - Incident & Breach Management	1	1	3	1	6
12 - Regulatory Reporting & Disclosure	1	1	2	1	5
Totals	13	14	44	13	84



15

Reference Data Model Dependency Map

Domain	D1	D2	D3	D4	D5	D6	D7	D8	D9	D10	D11	D12	Total (Out)
1 - Processing Inventory	1		1	2	2								6
2 - Purpose Specification & Governance	1	1		2					1				5
3 - Personal Data Inventory & Classification			1										1
4 - Legal Basis Management				1	2				1				4
5 - Entities, Roles, & Accountability					1								1
6 - Consent Management		1				1		1					3
7 - Data Subject Rights Management			1			1	1						3
8 - Notice & Transparency													0
9 - Risk & Impact Assessment					1				1		1		3
10 - Control Measures										1			1
11 - Incident & Breach Management	1								1		1	1	4
12 - Regulatory Reporting & Disclosure	1		1	1	1								5
Total (In)	4	2	4	6	3	2	1	1	4	1	2	3	38



16

Solution

Principles

- Three "Rings"
 - An invariant core** - Modify these entities and relationships at your peril.
 - A flexible periphery** - Modify these more freely to accommodate objectives.
 - Regulation Profile Extensions** - Apply these only if scoped under specific regulation, where unique entities or relationships may exist.
- # Explicit Decision Points
- Taxonomies as expressions of risk tolerance.
- Maturity keying as expressions of risk tolerance.



18

Key Characteristics of Data Model

- Schema
- Format
 - Schema
 - Turtle (.ttl) Format
 - ~1,200 Lines
 - Compatible with common ontological tools (e.g. Protégé) but visualized partially via the Interactive Model Explorer Web App for this project.



19

Demo of Reference Data Model Explorer Web App



20

Conclusions

21

Results

- Data Model [Add in description]
- Identified 13 "gaps" in the W3C DPV, of which, 10 are substantively implemented in this work.
- [Placeholder for how W3C Issues/Suggestions Resolve]
- Considering talk submission to IEEE ISoPE and/or USENIX PEPR.



22

Why does it matter?

- If you want to get better at something, be more precise.
- Al, sigh.
- **Some parting advice...**
 - Don't forget ontologies, taxonomies, reference schemas, etc. are a thing.
 - Next time you're tackling a problem, consider taking an ontological approach.
 - Ideate on what your data would look like if that problem no longer existed.
 - Work back from that.
 - Watch out for tool traps (weaknesses driven from places where you don't control your data structures).



23

Qualifications, Limitations, and Further Inquiry Areas

Qualifications and Limitations

- More stuff here.
- Deeper internal validity tests using synthetic data.
- Further Evaluation Needed for External Validity.

Further Inquiry Opportunities

- Using the Reference Data Model to evaluate data structures within commercial tools.



24



25